11/01/2012
Revised 03/13/2026

OPR: WVOT Cybersecurity

COMPLIANCE WITH THIS PUBLICATION IS MANDATORY

Publications are available online at:
https://sites.google.com/wv.gov/wvot-extranet/policy-governance/executive-branch-policies

Questions and change recommendations related to this publication shall be directed to this publication's Office of Primary Responsibility (OPR). This publication shall be reviewed every two years to ensure continued alignment with current legal, operational, and strategic requirements. Revisions will be undertaken as necessary.

SUMMARY OF VERSIONS AND CHANGES

Version	Date	Revision Description
	03/13/2026	Reformatted and updated web links and reporting process

1. PURPOSE

1.1. This procedure establishes standardized requirements and expectations for Information Security(IS) vulnerability assessments and remediation in regards to the State of West Virginia's executive domain and its users.

2. SCOPE

2.1. This procedure applies to all departments (including agencies, boards, authorities, and commissions) within the Executive Branch of WV State Government, excluding constitutional officers, the WV Board of Education, the WV Department of Education, and the county boards of education that have access to or use State-provided resources. However, the WVOT recommends that all agencies, including those excluded above, follow this procedure.

2.2. Where there are procedures in place which provide less restrictions or security than this procedure, those procedures will be superseded by this procedure. In instances where existing state and federal laws, regulations, and policies are more restrictive than this procedure, the more restrictive provisions will prevail.

3. PROCEDURE

3.1. Requirements

3.1.1. Under the provisions of West Virginia Code §5A-6-4a et seq., the Chief Information Office (CIO) is charged with securing State government information and the data communications infrastructure from unauthorized uses, intrusions, or other security threats.

3.1.2. The WVOT will adopt and implement standards, procedures, and best practices to minimize the risk of security breaches within the goals of this procedure. To the extent that there are procedures in place which provide less security than this procedure, they will be superseded by this document. In instances where existing state and federal laws and regulations are more restrictive than information security policies and procedures issued by the WVOT, the more restrictive provisions will prevail.

3.2. Procedure

3.2.1. User Responsibilities:

3.2.1.1. Users must report any observation of attempted security or privacy violations to: https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/

3.2.1.2. Users must immediately report all information security incidents to https://wv.accessgov.com/technology/Forms/Page/incident-reporting/incident-reporting/

3.2.1.3. Users must provide the following information, to the extent possible:

3.2.1.3.1. Point of contact (name, agency, phone, cell number, e-mail);

3.2.1.3.2. Physical location of incident (building, room#, etc.)

3.2.1.3.3. Date and time incident occurred and detected, is it ongoing;

3.2.1.3.4. Description of event (ex: unauthorized access, system breach or malfunction, data loss or exposure, defacement, and any actions taken in response to the incident.

3.2.1.3.5. Description of the extent of impact;

3.2.2. Chief Information Security Officer (CISO) Responsibilities:

3.2.2.1. Authorizing scheduled and random use of information security and risk assessment tools to evaluate State computer devices and applications. This will include testing websites for risk vulnerability as they pertain to confidentiality, integrity, and availability.

3.2.2.2. Coordinating the application of risk assessment tools with the Information Security Administrator (ISA) of each agency owning the system, agency policy influencing leaders, web coordinator(s) and/or the webmaster, and the hosting agency, in order to

minimize operational disruptions.

3.2.2.3. The CISO will evaluate all requests for exemption from this procedure. Requests must be received in writing and signed by the agency ISA or asset manager. The request must include business reasons justifying why the risk assessment methods, tools, and techniques should not be employed. The CISO will decide each case based on its merit; appeals of the decision may be made to the CIO.

3.2.3. WVOT Cybersecurity Office Responsibilities

3.2.3.1. Select and use all practical methods, tools, and technologies to evaluate the security of the State's computer devices and the applications that run on them. These may include, but are not limited to, tools that scan for common operating systems and application configuration and program vulnerabilities.

3.2.3.2. The OISC, along with input from the CIO, the ISA's, lead technical managers from the WVOT, and the Information Technology Advisory Council (ITAC), will establish security vulnerability standards, procedures, and best practices governing computer applications, chief network systems, and operating systems.

3.2.3.3. Conduct security assessments on all new major applications in accordance with the WVOT PO1025 Assessment and Authorization Policy.

3.2.3.4. The Cybersecurity Office will alert the agency's ISA, asset managers, and the policy influencing leadership of the agency that owns the system, when a critical information security deficiency is discovered.

3.2.3.4.1. The Cybersecurity Office will work together to correct the deficiency in a timely manner.

3.2.3.4.2. At the discretion of the CISO, the computer device or application may be removed from service until a satisfactory remediation is implemented.

3.2.3.4.3. The Cybersecurity Office will promptly provide a report to the agency ISA, asset managers, policy influencing leadership, and other designated individuals.

3.2.3.5. Cybersecurity Office staff will protect data supplied to evaluate risk, and will comply with all confidentiality requirements of the agency, including signing any necessary contracts/agreements.

3.2.3.6. If the Cybersecurity Office is able to breach security while testing,

they are prohibited from disclosing any confidential or personal data, or the source of the vulnerability without written authorization of the CISO and/or Agency Cabinet Secretary.

3.2.4. Information Security Administrator (ISA) Responsibilities:

3.2.4.1. Accountable for their agency's logical and physical security, and will be responsible for the following:

3.2.4.2. Implementing risk remediation findings required by the CISO;

3.2.4.3. Assisting the CISO in maintaining the State's information security;

3.2.4.4. Ensuring that all relevant requests for proposals (RFP) and resulting contracts with vendors contain language intended to enforce this procedure and its standards.

3.2.4.5. Assessing potential risks in existing systems and determining which should be evaluated for vulnerabilities and remediation.

3.2.5. West Virginia Office of Technology Staff Responsibilities:

3.2.5.1. Implementing the security vulnerability standards governing WVOT's applications, enterprise network systems, and operating systems;

3.2.5.2. Assisting the CISO in the conduct of his/her duties regarding the implementation of this procedure and its standards;

3.2.5.3. Remediating critical vulnerabilities within 10 days upon discovery;

3.2.5.4. Remediating high vulnerabilities within 20 days upon discovery;

3.2.5.5. Drafting a plan of action for medium vulnerabilities;

3.2.5.6. Regularly assessing security, and remediating vulnerabilities within their area of responsibility;

3.2.5.7. Alerting the CISO and the CIO when security vulnerabilities beyond the scope of their responsibility are discovered or suspected; and

3.2.5.8. Alerting the CISO and the CIO of any remediation actions, highlighting issues that they may not be able to correct, and documenting steps taken by using the WVOT's SOC remediation tracking system.

3.2.6. All IT Vendors/Contractors Responsibilities:

3.2.6.1. Must agree to recognize the State's right to conduct vulnerability testing in accordance with this procedure, and must agree to

support vulnerability testing and collaborate with the State to implement security remediation findings in applications for which they are responsible. With respect to systems implemented following the adoption of this procedure, in accordance with the terms of their contract(s), vendors/contractors must agree:

3.2.6.1.1. to provide a secure hosting environment for the contracted application;

3.2.6.1.2. to support periodic vulnerability testing conducted by the State and/or its agents; and

3.2.6.1.3. to remediate significant security vulnerabilities in a timely manner for the term of the contract.

4. POLICY-SPECIFIC DEFINITIONS

4.1. Access– The ability to locate, gain entry to, and use a directory, file, or device on a computer system or over a network.

4.2. Access Controls – The enforcement of specified authorization rules based on positive identification of users and the systems or data they are permitted to access.

4.3. Authentication – The process of verifying the identity of a user.

4.4. Chief Information Security Officer (CISO) – Person designated by the CIO to oversee information security practices and initiatives for the Executive Branch of WV State government, excluding the constitutional officers.

4.5. Chief Technology Officer (CIO) – The person responsible for the State's information resources.

4.6. Confidential Data – Information that is legally protected (ex: Protected Health Information) or otherwise deemed by a qualified expert to be unsuitable for open access.

4.7. Contractor – Anyone who has a contract with the State or one of its entities.

4.8. Custodian of Information – The person or unit assigned to supply services associated with the data.

4.9. Employee – Individuals retained and authorized on a temporary or permanent basis by the State of West Virginia to perform a service. For the purposes of information technology and security policy, the term "employee" shall include the following: contractors, subcontractors, contractors' employees, volunteers, county health department staff, business associates, and any other persons who are determined and notified by the WVOT to be subject to this policy. This definition does not create any additional rights or duties.

4.10. Information Assets – Any of the data, hardware, software, network, documentation, and personnel used to manage and process information.

4.11. Information Resources – All information assets, in all known formats.

4.12. Information Security – Those measures, procedures, and controls that provide an acceptable degree of safety for information resources, protecting them from accidental or intentional disclosure, modification, or destruction.

4.13. Information Security Administrator (ISA) – The person designated by the agency head to assure the agency's compliance with State information security policies and procedures. The ISA is the agency's internal and external point of contact for all information security matters.

4.14. Information Security Incident – An event characterized by unexpected and unwanted system behavior, breach, or unintended alteration of data.

4.15. Information Security Liaison (ISL) - Employees assigned by the ISA to assist in the protection of information resources.

4.16. Information Technology (IT) – The technology involved with the transmission and storage of information, especially the development, installation, implementation, and management of computer systems and applications.

4.17. Medium – Any repository, including paper, used to record, maintain, or install information or data.

4.18. Owner of Information – The person(s) ultimately responsible for an application and its data viability.

4.19. Password – A string of characters known to a computer system or network and to a user who must enter the password in order to gain access to an information resource.

4.20. Personally Identifiable Information (PII) –Includes all protected and non-

4.21. protected information that identifies, or can be used to identify, locate, or contact an individual.

4.22. Privacy Officer - The official responsible for facilitating the Executive Branch's integration of privacy principles, legal requirements, and privacy standards into department policies, procedures, and practices.

4.23. Procedure – A set of instructions or process steps prescribed in sufficient detail in order to understand how to meet a policy requirement. Procedures should document roles, methods, options, and examples necessary for a reader to understand how to comply with a policy.

4.24. Risk Analysis – The evaluation of system assets and their vulnerabilities to

threats in order to identify what safeguards are needed.

4.25. Security Contact – These individuals include the ISA or the ISL.

4.26. Threat – Includes any person, condition, or circumstance that endangers the security of information or information systems in the context of information security.

4.27. User – A person authorized to access an information resource.

4.28. User id – A unique “name” by which each user is identified to a computer system.

4.29. West Virginia Division of Personnel – A division of the Department of Administration established by West Virginia Code § 29-6-1 et seq., which is responsible for the system of human resource management for operating agencies in the classified and classified-exempt service of West Virginia State government.

4.30. West Virginia Office of Technology (WVOT) - The division of the Department of Administration established by WV Code § 5A-6-4a, et. seq., which is led by the State’s CIO and designated to acquire, operate, and maintain the State’s technology infrastructure. The WVOT is responsible for evaluating equipment and services, and reviewing information technology contracts.

5. RELEVANT MATERIALS AND DOCUMENTS

5.1. This policy is consistent with the following federal and state authorities:

5.1.1. NIST SP 800-14 and NIST SP 800-53

5.1.2. W. Va. Code § 5A-6-4a

5.1.3. WVOT PO1025 Assessment and Authorization Policy